

Vulnerability Assessment Report

CloudExify — Project 4 (Cybersecurity, Month 2)

Prepared by: Raheen (RaheenIfham)
CloudExify Summer Internship 2026

Confidential — For Internal Review Only

Table of Contents

1. Executive Summary
2. Findings Summary
3. Detailed Technical Findings
4. Remediation Roadmap
5. Testing Methodology
6. Appendices

1. Executive Summary

CloudExify conducted a Vulnerability Assessment of the target web application and its underlying infrastructure, combining automated scanning (Nessus) with manual security testing to identify and confirm exploitable weaknesses.

The assessment identified 10 confirmed vulnerabilities, including 4 rated Critical and 3 rated High severity. Most critically, two vulnerabilities (Unrestricted File Upload and Command Injection) allow an attacker to execute arbitrary commands on the server itself — effectively granting full control of the system without needing any special access. Additional high-risk findings include SQL Injection, which exposes the entire user database, and an account lockout weakness that allows unlimited password-guessing attempts.

Given the severity of these findings, immediate remediation is recommended for the Critical and High-severity issues (within 24 hours to 7 days), while Medium-severity findings (such as cross-site scripting and CSRF) should be addressed within 30 days. All identified vulnerabilities have clear, low-cost technical fixes — primarily software updates and standard secure-coding practices — making remediation straightforward once prioritized.

2. Findings Summary

#	Finding	Severity	Business Impact
1	Unrestricted File Upload	Critical	Attacker can run any code on the server, gaining full control of the system
2	Command Injection	Critical	Attacker can execute operating system commands directly on the server
3	Outdated Apache Web Server	Critical	Multiple known security flaws could allow server compromise or crashes
4	Outdated PHP	Critical/High	Known flaws could allow attackers to run code or access sensitive files
5	SQL Injection	High	Attacker can extract the entire user database, exposing all customer/user data
6	No Account Lockout (Brute Force)	High	Attacker can repeatedly guess passwords without restriction until successful
7	Cross-Site Request Forgery (CSRF)	Medium	Attacker can trick a logged-in user into unknowingly changing account settings
8	Reflected Cross-Site Scripting (XSS)	Medium	Attacker can run malicious scripts in a victim's browser via a crafted link
9	Stored Cross-Site Scripting (XSS)	Medium	Malicious scripts persist on the site and run automatically for every visitor
10	Outdated OpenSSL	Low-Medium	Encryption library has known flaws; low current risk since HTTPS isn't active

Overall Risk Level: High — 4 Critical and 3 High-severity findings require prompt attention; remaining findings are lower risk but should still be remediated within standard timelines.

3. Detailed Technical Findings

VULNERABILITY: Unrestricted File Upload → Remote Code Execution

Severity: Critical (CVSS 9.9)

Status: Confirmed

Description

DVWA's File Upload module does not validate the type or content of uploaded files at Low security. Any file, including executable server-side scripts, can be uploaded and is stored in a web-accessible directory, allowing direct execution via URL.

Proof of Concept

Uploaded a PHP file (validate_day8.php) containing:

```
<?php echo "RCE confirmed - Day 8 validation"; ?>
```

via DVWA's File Upload form. Upload succeeded with confirmation: "../hackable/uploads/validate_day8.php successfully uploaded!"

Result

Navigating directly to http://localhost/DVWA/hackable/uploads/validate_day8.php executed the PHP code on the server, rendering "RCE confirmed - Day 8 validation" as live output rather than serving it as plain text or a downloadable file.

Root Cause

The application performs no server-side validation of file extension or file content (e.g., MIME type checking) before storing uploads, and stores files in a directory where the web server will execute scripts.

CVSS Vector: AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

VULNERABILITY: OS Command Injection

Severity: Critical (CVSS 9.9)

Status: Confirmed

Description

DVWA's Command Injection module (Ping a Device) passes user input directly to the underlying OS shell without sanitization, allowing arbitrary command chaining.

Proof of Concept

Baseline: 127.0.0.1 → normal ping output.

Payload: 127.0.0.1 && hostname

Result

Ping executed normally (4 packets, 0% loss), and the injected hostname command additionally returned the server's machine name (DESKTOP-NS3Q0FG), confirming arbitrary OS command execution alongside the intended function.

Root Cause

User input is concatenated directly into a shell command without input sanitization or use of safe API alternatives, allowing shell metacharacters (&&) to chain additional commands.

CVSS Vector: AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

VULNERABILITY: SQL Injection

Severity: High (CVSS 7.7)

Status: Confirmed

Description

DVWA's SQL Injection module concatenates user input directly into a SQL query without parameterization, at both Low and Medium security levels (Medium filters quotes but not numeric-based bypasses).

Proof of Concept

Low: ' OR '1'='1

Medium: 1 OR 2=2 (bypasses quote-escaping filter)

Result

Both payloads returned all 5 user records (admin, Gordon Brown, Hack Me, Pablo Picasso, Bob Smith) instead of a single queried user, confirming the query's WHERE clause logic was bypassed.

Root Cause

The application builds SQL queries via direct string concatenation of user input rather than parameterized queries/prepared statements. Medium security's quote-escaping is insufficient since numeric-based payloads require no quotes.

CVSS Vector: AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N

VULNERABILITY: No Account Lockout (Brute Force)

Severity: High (CVSS 7.1)

Status: Confirmed

Description

DVWA's login mechanism does not enforce any limit on failed login attempts, allowing unlimited automated password guessing.

Proof of Concept

Used Burp Suite Intruder to submit multiple password attempts against the login form.

Result

Failed attempts returned a consistent response length (4863-4864 bytes), while the correct password returned a distinctly different length (4907 bytes), allowing the correct password to be identified without manual verification of each attempt.

Root Cause

No rate limiting, CAPTCHA, or account lockout mechanism is implemented after repeated failed login attempts.

CVSS Vector: AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N

VULNERABILITY: Cross-Site Request Forgery (CSRF)

Severity: Medium (CVSS 6.5)

Status: Confirmed

Description

DVWA's password change function does not implement a CSRF token at Low security, allowing state-changing requests to be forged from an external source.

Proof of Concept

Hosted csrf_validate_day9.html (containing a hidden tag pointing to the password-change endpoint) same-origin within XAMPP's htdocs folder to bypass the SameSite=Strict cookie restriction.

Result

Opening the file while logged into DVWA silently changed the account password to validated123 without user consent, confirmed by successful login with the new password.

Root Cause

No server-side CSRF token validation is performed on the password-change request; reliance on SameSite=Strict alone is insufficient when the malicious page is hosted same-origin.

CVSS Vector: AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:H/A:N

VULNERABILITY: Reflected Cross-Site Scripting (XSS)

Severity: Medium (CVSS 6.1)

Status: Confirmed

Description

DVWA's Reflected XSS module renders user input directly into the page response without escaping.

Proof of Concept

Payload: <script>alert("Test123")</script>

Result

The script executed immediately, displaying a browser popup ("localhost says Test123"), confirming the input was rendered as executable code rather than plain text.

Root Cause

User input is reflected into the HTML response without output encoding/escaping (e.g., htmlspecialchars()).

CVSS Vector: AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N

VULNERABILITY: Stored Cross-Site Scripting (XSS)

Severity: Medium (CVSS 5.4)

Status: Confirmed

Description

DVWA's Stored XSS module (guestbook/comment feature) persists unescaped user input in the database, executing for every visitor who views the page.

Proof of Concept

Payload:

Result

The payload persisted and re-executed automatically on every page load until manually removed, unlike Reflected XSS which fires only once.

Root Cause

Input is stored without sanitization and rendered without output escaping on display.

CVSS Vector: AV:N/AC:L/PR:L/UI:R/S:U/C:L/I:L/A:N

VULNERABILITY: Outdated Apache Web Server

Severity: Critical (CVSS 9.8)

Status: Confirmed (version-based detection)

Description

Installed Apache version (2.4.58) is below the patched version (2.4.67), exposing the host to multiple CVEs.

Proof of Concept

Verified via `httpd -v` → "Apache/2.4.58 (Win64)". Cross-referenced against Nessus scan results (Days 4-5).

Result

Confirmed applicable CVEs: CVE-2026-28780 (heap buffer overflow), CVE-2026-23918 (double-free/possible RCE via HTTP/2), CVE-2026-24072 (privilege escalation via `.htaccess`), CVE-2026-29168 (DoS via `mod_md`).

Root Cause

Software has not been updated since installation; no patch management process in place. Note: Nessus flagged this via self-reported version string, not active exploitation testing.

VULNERABILITY: Outdated PHP

Severity: Critical/High/Medium (version-threshold dependent)

Status: Confirmed (version-based detection)

Description

Installed PHP version (8.2.12) is below multiple patched thresholds (8.2.20, 8.2.24, 8.2.32).

Proof of Concept

Verified via `phpinfo()` → PHP 8.2.12. Cross-referenced against Nessus scan results.

Result

Confirmed applicable CVEs: CVE-2024-4577 and CVE-2024-8926 (command injection via Windows Best-Fit codepage handling), CVE-2022-31629 (insecure cookie handling).

Root Cause

Software has not been updated since installation. Note: Nessus flagged some findings via self-reported version string only.

VULNERABILITY: Outdated OpenSSL

Severity: Low-Medium (Nessus-flagged range < 3.1.8)

Status: Confirmed (version-based detection)

Description

Installed OpenSSL version (3.1.3, bundled with XAMPP/Apache) falls below the patched threshold (3.1.8).

Proof of Concept

Verified via openssl version → "OpenSSL 3.1.3 19 Sep 2023".

Result

Version confirmed within Nessus's flagged vulnerable range.

Root Cause

Bundled library not updated since XAMPP installation. Current real-world exposure is low since HTTPS is not actively used in this environment.

4. Remediation Roadmap

Critical (0–24 hours)

- Unrestricted File Upload → RCE
- OS Command Injection
- Outdated Apache Web Server

High (1–7 days)

- SQL Injection
- No Account Lockout (Brute Force)
- Outdated PHP (Critical/High threshold findings)

Medium (1–30 days)

- Cross-Site Request Forgery (CSRF)
- Reflected XSS
- Stored XSS
- Outdated OpenSSL

Low (Continuous Improvement)

- Nessus install directory permission hardening (non-admin write access flag)

5. Testing Methodology

Tools Used

- Nessus Essentials 10.12.3 (automated vulnerability scanning — network + web application)
- Manual browser-based testing (Chrome) for DVWA application-layer validation
- Command Prompt (netstat, httpd -v, mysql --version, openssl version) for infrastructure enumeration
- Burp Suite Community Edition (carried over from Project 3, used for CSRF/brute force evidence)

Scope

- Target: localhost (127.0.0.1), XAMPP stack (Apache 2.4.58, PHP 8.2.12, MariaDB 10.4.32, OpenSSL 3.1.3), DVWA application
- Out of scope: any host/device beyond localhost, home network infrastructure, third-party systems

Limitations

- Nessus's network interface did not support packet forgery, potentially limiting full port-scan coverage
- Nessus's Apache/PHP findings were based on self-reported version strings, not active exploitation testing
- Burp Suite Community Edition lacks the automated Scanner feature (Professional-only); all DVWA application vulnerabilities were identified through manual testing
- Nessus did not independently detect DVWA's intentional application-layer vulnerabilities (SQLi, XSS, CSRF, Command Injection, File Upload) — these required manual validation

6. Appendices

A. Detailed Scan Results

Nessus scan exports and screenshots — Network Scan and Web Application Scan (see accompanying screenshots folder in project repository).

B. Screenshots of Vulnerabilities

Manual validation screenshots for File Upload/RCE, Command Injection, SQL Injection, and CSRF (see accompanying screenshots folder).

C. Configuration Recommendations

See Section 4 (Remediation Roadmap) for full remediation steps per finding.

D. Glossary of Technical Terms

- CVSS — Common Vulnerability Scoring System; standardized 0–10 severity rating
- RCE — Remote Code Execution; attacker runs arbitrary code on a target system
- CSRF — Cross-Site Request Forgery; forces a logged-in victim to perform unintended actions
- XSS — Cross-Site Scripting; injection of malicious scripts into web pages viewed by others
- SQL Injection — manipulating a database query via unsanitized user input
- CVE — Common Vulnerabilities and Exposures; publicly catalogued vulnerability identifier
- EPSS — Exploit Prediction Scoring System; probability a vulnerability will be exploited in the wild